



Dossier technique et sécurité

Version 2.2 — 30 septembre 2026

Plateforme de santé pour le Sénégal : rendez-vous, téléconsultation, dossier médical, paiement mobile, assurances, pharmacies.

Public : acquéreurs, investisseurs, auditeurs techniques et juridiques, équipe de reprise.

Document confidentiel. Il décrit l'architecture et les mesures de sécurité de la plateforme. À transmettre uniquement sous accord de confidentialité.

Dossier technique et sécurité — Fajma

Version du dossier : 2.5 — 30 septembre 2026 **Périmètre :** code source du dépôt `sante-connect-main` (backend Django, frontend React, déploiement), services tiers. **Public visé :** acquéreurs, investisseurs, auditeurs techniques et juridiques, équipe technique reprenant le projet.

Cette version remplace entièrement la version 1.x, qui décrivait le prototype initial (Supabase, Lovable Cloud). Le produit a depuis été reconstruit : backend Django, base PostgreSQL maîtrisée, aucune dépendance à Lovable ni à Supabase.

1. Fiche d'identité

Élément	Valeur
Produit	Plateforme de santé pour le Sénégal : prise de rendez-vous, téléconsultation, dossier médical, paiement, assurances, pharmacies
Utilisateurs	Patients (et leurs proches), médecins, cliniques (responsables, secrétariat), pharmaciens, laboratoires d'analyses, administrateurs
Canaux	Site web et application installable (PWA, publiable sur le Play Store), WhatsApp, USSD (tout téléphone, sans internet)
Langues	Français, wolof (à faire relire par un locuteur natif), anglais ; SMS et menus dans la langue du patient
Backend	Python 3.13, Django 6.1, Django REST Framework ; file de tâches <code>django.tasks</code>
Frontend	React 19, TanStack Router/Start (mode SPA), Tailwind CSS 4, TypeScript
Base de données	PostgreSQL 17 en production (SQLite en développement)
Hébergement	Docker Compose sur un serveur au choix — un hébergement au Sénégal est possible sans modification
Paieement	PayDunya (Wave, Orange Money, Free Money, cartes) ou règlement au cabinet
Messages	Twilio : SMS et WhatsApp ; notifications push du navigateur (Web Push, gratuites)
Téléconsultation	Jitsi Meet (serveur public au démarrage, auto-hébergeable)
Assistant IA	Fournisseur configurable via une API compatible OpenAI (Google Gemini par défaut)
Qualité	230 tests automatisés de l'API ; parcours de bout en bout dans un navigateur réel pour chaque rôle ; intégration continue GitHub Actions
Taille du code	≈ 13 200 lignes Python (hors tests et migrations), ≈ 3 200 lignes de tests, ≈ 28 500 lignes TypeScript/React

2. Contenu du dossier

#	Document	Contenu
1	Architecture	Composants, organisation du code, fonctionnalités, modèle de données, intégrations
2	Sécurité	Authentification, contrôle d'accès, protections, secrets, journal d'audit, tests
3	Données personnelles et conformité	Inventaire des données, sous-traitants, droits des personnes, obligations au Sénégal
4	Exploitation et déploiement	Installation, mise en production, tâches planifiées, sauvegardes, supervision
5	Risques et plan d'action	Points ouverts, gravité, actions avant commercialisation

#	Document	Contenu
6	Informations pour une cession	Propriété, licences des composants, dépendances aux prestataires, coûts, reprise par une autre équipe

3. Synthèse pour la direction

Ce qui est en place

- **Couverture fonctionnelle de niveau Doctolib, adaptée au Sénégal** : réservation (site, WhatsApp, USSD), téléconsultation, dossier médical, ordonnances et certificats vérifiables par QR code, paiement mobile avec commission et reversement aux médecins, abonnements des médecins, assurances (IPM, mutuelles CMU, assureurs) avec tiers payant, carnet de vaccination et suivi de grossesse, ordonnances transmises aux pharmacies, secrétariat de clinique ou de cabinet, télé-expertise entre médecins, visites à domicile, séries de séances (kinésithérapie, soins), remplacements entre médecins, tableau de pilotage.
- **Chaque acteur gère lui-même ses informations** : fiche et photo du médecin, horaires et garde de la pharmacie, informations de la clinique ; l'administration dispose des outils de support (recherche de compte, suspension, réinitialisation de la double authentification, ajout de pharmacies).
- **Le contrôle d'accès est appliqué par le serveur** pour chaque requête, et vérifié par des tests automatisés (tentatives d'accès aux données d'un autre patient, d'un autre médecin, d'une autre pharmacie...).
- **Traçabilité** : chaque consultation d'un dossier par un professionnel est inscrite dans un journal inaltérable, visible par le patient concerné.
- **Argent tracé** : journal comptable non modifiable par médecin ; paiements vérifiés directement auprès de PayDunya ; remboursement automatique en cas d'annulation.
- **Sécurité des comptes** : double authentification (TOTP) **obligatoire pour tous les professionnels et administrateurs**, connexion par code SMS pour les patients, sessions HttpOnly, limites de débit, en-têtes de sécurité et politique CSP stricte.
- **Exploitation** : sauvegardes quotidiennes chiffrées avec test de restauration mensuel automatique, supervision avec alertes email, purge nocturne des données techniques selon des durées de conservation.
- **Souveraineté** : l'ensemble de la plateforme (base, fichiers, API) peut être hébergé au Sénégal ; les seuls flux sortants sont ceux des prestataires listés (SMS, IA, vidéo si non auto-hébergée).

Ce qui doit être fait avant une commercialisation (détail : [plan d'action](#))

1. **Règlementaire** : autorisation de la CDP pour le traitement de données de santé ; encadrement des transferts hors du Sénégal ; validation par un juriste des CGU et de la politique de confidentialité (projets fournis) ; qualification juridique de l'encaissement pour le compte des médecins.
2. **Téléconsultation** : héberger Jitsi (ou un service contractualisé) au lieu du serveur public.
3. **Validation médicale** : calendrier vaccinal (PEV) et consultations prénatales à faire valider par la Direction de la Prévention ; textes wolof à faire relire.
4. **Test d'intrusion** par un prestataire indépendant, puis exploitation sur l'infrastructure cible (HTTPS, première restauration de sauvegarde, abonnement à un moniteur de disponibilité externe).
5. **Contrats opérateurs** : Twilio (numéros, modèles WhatsApp approuvés), agrégateur USSD, PayDunya en production ; les virements aux médecins et remboursements sont aujourd'hui exécutés manuellement par l'administration, qui en saisit la référence.

4. Méthode

Dossier établi par lecture intégrale du code source, exécution de la suite de tests de l'API (230 tests) et de parcours de bout en bout dans un navigateur réel (Chrome et Edge, ordinateur et mobile) : patient, médecin, médecin remplaçant, clinique, secrétariat, pharmacien, administrateur, activation obligatoire de la double authentification, mode hors ligne sur le build de production.

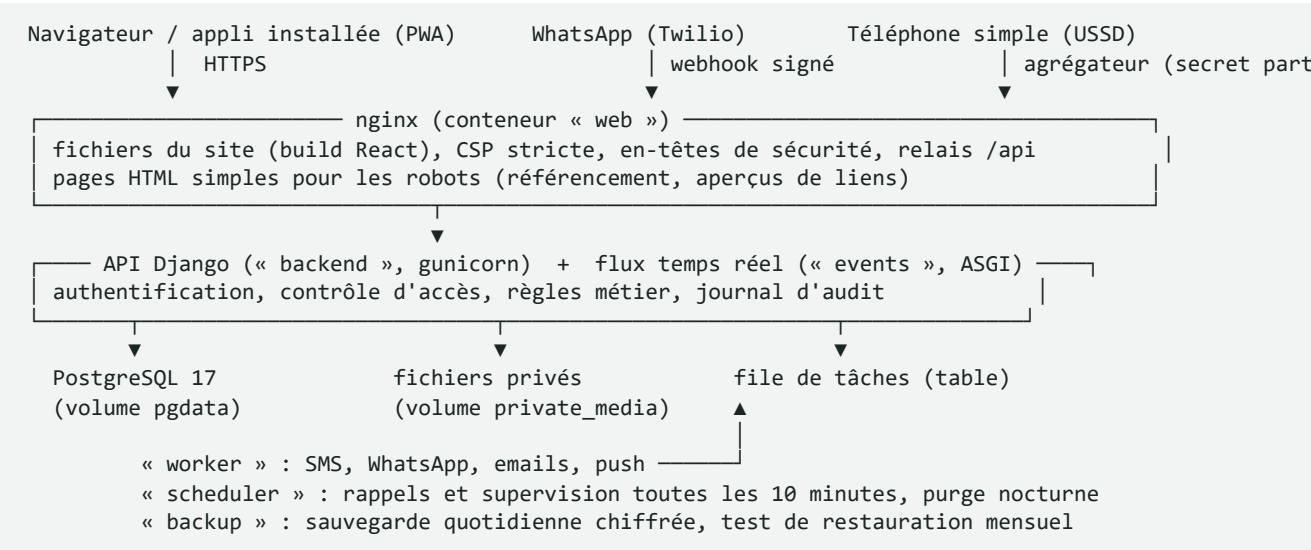
Limites : les intégrations externes (PayDunya, Twilio, agrégateur USSD, service push des navigateurs, Jitsi) ont été testées avec des réponses simulées, faute d'accès réseau et de comptes de production dans l'environnement d'audit. Le déploiement Docker et le script de test de restauration n'ont pas pu être exécutés dans cet environnement (la composition a été validée par `docker compose config`, les scripts par `sh -n`). Ces points sont signalés « **À vérifier** ».

5. Historique des versions

Version	Date	Changements
1.x	2026	Prototype initial (Supabase, Lovable Cloud)
2.0	29/09/2026	Reconstruction complète (Django, PostgreSQL), dossier réécrit
2.1	30/09/2026	Visites à domicile, séries de séances, remplacements ; double authentification obligatoire pour les professionnels ; outils d'administration ; fiches modifiables par chaque acteur ; supervision, test de restauration, purge des données ; chapitre 6 (cession)
2.2	30/09/2026	Agenda tenu par le cabinet (saisie et déplacement de RDV), pièces jointes dans la messagerie, exports tableur (dont bordereau de tiers payant) ; suivi à domicile (tension, glycémie, poids), rappels de médicaments, laboratoires d'analyses, disponibilité des médicaments en pharmacie, pages publiques des cliniques, « Mes médecins », messagerie avec le remplaçant
2.3	30/09/2026	Mise en service simulée avec de vrais comptes pour chaque rôle. Corrections : la mise à jour du profil ne peut plus effacer ni « garder vérifié » un numéro changé (sécurité) ; géolocalisation automatique des cabinets (recherche par quartier) ; file « À traiter » et menu de l'administration ; notifications de validation, de rattachement, de nouvelle ordonnance et de compte-rendu ; alerte « en-tête d'ordonnance incomplet » ; compte-rendu et ordonnance possibles après « Terminé » ; affichage mobile de l'espace patient et du dossier
2.4	30/09/2026	Renforcements avant mise en service : fichiers chiffrés sur le disque, antivirus (ClamAV), déconnexion des professionnels après 30 min d'inactivité, alerte de connexion depuis un nouvel appareil, contrôle des failles des bibliothèques serveur (pip-audit)
2.5	30/09/2026	Revue de toutes les pages. Espace médecin en onglets et vrai écran « Emploi du temps » (semaine visuelle, plages sur plusieurs jours, modification, chevauchements refusés, aperçu patient) ; aperçu d'ordonnance (spécimen) ; signature exigeant un vrai tracé ; logo Fajma sur les documents ; page publique « Tarifs » ; accueil sans données inventées (vrais médecins disponibles, allégations non vérifiables retirées) ; déconnexion dans les espaces pharmacie, laboratoire, clinique et administration ; corrections d'affichage mobile

1. Architecture

1.1 Vue d'ensemble



Services externes : PayDunya (paiement), Twilio (SMS, WhatsApp), service push des navigateurs, Jitsi (vidéo), fournisseur d'IA (assistant d'orientation), agrégateur USSD, fournisseur SMTP (emails).

1.2 Organisation du code

Dossier	Rôle
backend/sunusante/	Configuration, routes de l'API, outils communs (validation des entrées, fichiers déposés), tableau de pilotage
backend/accounts/	Comptes, connexion (mot de passe, code SMS, double authentification), profil, proches, export et suppression des données
backend/directory/	Annuaire, fiches médecin, créneaux, avis et modération, justificatifs (diplômes), espace médecin, référencement
backend/appointments/	Rendez-vous, calcul des créneaux, questionnaire avant consultation, liste d'attente, téléconsultation
backend/payments/	Paiements PayDunya, journal comptable des médecins, virements, remboursements, abonnements
backend/insurance/	Organismes (IPM, CMU, assureurs), couvertures des patients, tiers payant
backend/medical/	Comptes-rendus, ordonnances, certificats et arrêts de travail, documents, profil de santé, rappels
backend/carnet/	Carnet de vaccination (calendrier PEV), suivi de grossesse (CPN), rappels
backend/pharmacy/	Pharmacies partenaires, ordonnances transmises et leur préparation
backend/clinics/	Cliniques, secrétariat, agenda partagé, fichier patients et doublons
backend/expertise/	Télé-expertise et messagerie entre médecins
backend/messaging/	Messagerie patient ↔ médecin
backend/bots/	Menu WhatsApp et USSD (moteur commun, textes en trois langues)
backend/notifications/	SMS/WhatsApp, emails, notifications push, tâches en arrière-plan, rappels planifiés

Dossier	Rôle
backend/care/	Suivi à domicile (mesures, repères indicatifs) et rappels de prise de médicaments
backend/labs/	Laboratoires d'analyses : prescription, choix du laboratoire, prélèvement, dépôt des résultats
backend/audit/	Journal d'audit inaltérable ; commandes d'exploitation <code>monitor</code> (supervision) et <code>purge_data</code> (conservation)
backend/tests/	Tests automatisés de l'API
src/	Interface React : <code>api/</code> (appels à l'API), <code>routes/</code> (pages), <code>components/</code> , <code>lib/</code> (traductions, dates, PDF)
public/	Manifeste PWA, service worker (hors ligne, notifications), icônes
deploy/	Docker Compose, images, nginx, politique CSP, variables de production

1.3 Fonctionnalités

Domaine	Détail
Recherche	Spécialité, ville, nom (sans accents), langue parlée, assurance acceptée, prix, disponibilité (aujourd'hui, semaine), téléconsultation, tri, carte (OpenStreetMap)
Réservation	Créneaux calculés par le serveur (plages, absences, délai minimal, horizon, durée du motif), multi-lieux, pour soi ou un proche, confirmation automatique ou par le médecin, anti-chevauchement garanti en base (contrainte d'exclusion PostgreSQL)
Visites à domicile	Plages horaires dédiées (trajet compris), supplément de déplacement, zone desservie, adresse + repère + position GPS facultative, itinéraire pour le médecin
Séries de séances	Motif réservable en série (kiné, pansements : 2 à 20 séances, tous les 1/2/3/7/14 jours), aperçu des dates libres, un seul message récapitulatif, annulation de la suite de la série ; le médecin ou le secrétariat peut ajouter des séances à tout rendez-vous
Remplacements	Le titulaire propose une période à un confrère vérifié, qui accepte ; l'agenda reste ouvert, le remplaçant reçoit les patients, accède au dossier pendant la période et signe à son nom (mention « remplaçant du Dr X ») ; paiements versés au titulaire
Après réservation	Déplacement, annulation (délai fixé par le médecin), fichier agenda <code>.ics</code> , rappels 24 h et 2 h, liste d'attente avec alerte, questionnaire avant consultation
Téléconsultation	Salle d'attente, prépaiement optionnel, salle vidéo au nom aléatoire ouverte par le médecin
Dossier patient	Profil de santé, documents (PDF, images), partage explicite avec un médecin, comptes-rendus, ordonnances, certificats, journal des accès, export et suppression du compte
Documents médicaux	Ordonnances, certificats, arrêts de travail, courriers : PDF signé électroniquement avec QR de vérification publique (sans contenu médical ni identité complète)
Carnet de santé	Calendrier vaccinal PEV de chaque enfant (statuts à faire / en retard / fait, dose vérifiée par le médecin), suivi de grossesse (terme, 8 consultations prénatales), déclaration de naissance qui crée le carnet du bébé, rappels SMS
Argent	Paiement mobile ou au cabinet ; commission selon l'abonnement du médecin ; solde et demandes de virement ; remboursement automatique en cas d'annulation d'un RDV payé ; reçu servant de feuille de soins
Assurances	Couvertures du patient (numéro, taux, validité, pour un proche) ; organismes acceptés par le médecin, avec ou sans tiers payant ; part patient calculée et figée à la réservation
Pharmacies	Envoi d'une ordonnance à une pharmacie partenaire, préparation (reçue → en préparation → prête / indisponible → retirée), montant, notification du patient

Domaine	Détail
Clinique	Équipe médicale, secrétariat, agenda partagé, RDV au guichet (même sans compte), fichier patients, détection et fusion des doublons, rattachement au compte du patient ; le responsable modifie les informations de l'établissement et retire un médecin qui part
Suivi à domicile	Le patient note tension, glycémie (g/L, à jeun ou après repas) et poids, pour lui ou un proche ; courbe, repères indicatifs (tension $\geq$ 180/110 : conseil d'appeler le 1515 ; hypoglycémie $<$ 0,7 g/L) ; les médecins qui le suivent voient la courbe dans la fiche patient
Rappels de médicaments	Heures de prise (1 à 6 par jour), durée du traitement, pour soi ou un proche, à partir d'une ordonnance ou en saisie libre ; notification gratuite, SMS/WhatsApp en option ; envoi par le planificateur, sans doublon
Laboratoires	Le médecin prescrit des analyses pendant la consultation ; le patient choisit un laboratoire partenaire ; le laboratoire enregistre le prélèvement et dépose les résultats (PDF), qui rejoignent le dossier du patient et sont partagés avec le prescripteur ; patient et médecin prévenus
Disponibilité des médicaments	« Avez-vous ce médicament ? » : le patient interroge jusqu'à 5 pharmacies partenaires (5 demandes par jour), qui répondent sous 24 h (disponible, prix, indisponible) sans connaître son identité
Annuaire	Pages publiques des cliniques et centres de santé vérifiés, avec leurs médecins et prochains créneaux (les cabinets individuels n'y figurent pas) ; « Mes médecins » : médecins consultés et reprise de RDV en un clic
Agenda tenu par le cabinet	Le médecin (ou son secrétariat) saisit un RDV pris au téléphone ou au cabinet, pour un patient connu ou sans compte, et déplace un RDV (patient prévenu par SMS) ; hors plages en ligne autorisé, jamais sur un autre RDV ni pendant une absence
Exports	Tableur (CSV pour Excel) : rendez-vous, bordereau de tiers payant par organisme, revenus ; agenda de la clinique ; chaque export est journalisé
Messagerie	Patient ↔ médecin, y compris le remplaçant qui l'a reçu ; texte et pièces jointes (photo ou PDF, type réel contrôlé, 6 Mo), accessibles aux seuls participants du fil
Espace médecin	Fiche publique modifiable (présentation, tarif, langues, téléconsultation, adresse) et photo ; nom et spécialité figés après vérification ; « Mon secrétariat » : un médecin seul donne l'accès à son agenda à sa secrétaire par simple email
Espace pharmacie	Horaires, jours d'ouverture, coordonnées et garde (avec date de fin, retrait automatique de la liste des pharmacies de garde) gérés par le pharmacien
Administration	Validation des médecins et établissements, justificatifs, modération, finances (virements, remboursements), rattachement des pharmaciens, recherche de comptes, suspension/réactivation, réinitialisation de la double authentification, ajout et correction des pharmacies , rappels SMS, journal d'audit
Médecins entre eux	Télé-expertise avec dossier et documents partagés (patient informé), messagerie
Confiance	Avis après consultation, réponse du médecin, signalement, modération ; publication d'un médecin conditionnée à la validation de son inscription à l'Ordre
Canaux	WhatsApp, USSD, notifications push, messages et alertes en temps réel (Server-Sent Events), application installable, mode hors ligne, module de réservation intégrable au site du médecin
Agenda du médecin	Abonnement privé à ses RDV depuis Google Agenda / Outlook / iPhone (initiales seulement) ; import de ses occupations personnelles (adresse iCal secrète), qui bloquent les créneaux
Pilotage	Activité hebdomadaire, taux d'absence, part de téléconsultation, canaux, spécialités et villes, volumes financiers
Référencement	Plan du site, pages HTML pour les robots, données structurées schema.org

1.4 Modèle de données (principales tables)

Table	Contenu
accounts_user, accounts_relative	Comptes (email et/ou téléphone vérifié, langue), proches
accounts_twofactor, accounts_otpcode	Double authentification, codes SMS (empreintes uniquement)
directory_doctor, ..._doctorlocation, ..._doctoravailability, ..._timeoff, ..._consultationtype	Fiches (photo, visites à domicile), lieux, plages (cabinet ou domicile), absences, motifs, tarifs, séries, questionnaires
directory_replacement	Remplacements entre médecins (période, statut)
directory_pharmacy	Officines (horaires, jours d'ouverture, garde et fin de garde)
directory_review, directory_doctorcredential	Avis (modération, réponse), justificatifs des médecins
appointments_appointment, ..._appointmentseries, ..._waitlistentry	Rendez-vous (canal, assurance figée, questionnaire, adresse de visite, médecin remplaçant, rang dans une série), séries de séances, liste d'attente
payments_payment, ..._refund, ..._payout, ..._ledgerentry, ..._subscription, ..._subscriptionpayment	Paielements, remboursements, virements, journal comptable, abonnements
insurance_insurer, ..._patientcoverage, ..._doctorinsurer	Organismes, couvertures, organismes acceptés
medical_*	Comptes-rendus, ordonnances, documents, partages, profils de santé, notes privées, rappels, documents rédigés
carnet_*	Doses de vaccin, rappels envoyés, grossesses, consultations prénatales
pharmacy_*	Pharmaciens rattachés, ordonnances transmises
clinics_*, expertise_*, messaging_*	Cliniques et personnel, télé-expertise, messages
notifications_*	Notifications, rappels SMS, abonnements push
bots_botsession	Conversations WhatsApp/USSD en cours
care_measurement, care_medicationreminder	Mesures à domicile, rappels de médicaments
labs_laboratory, ..._laboratorymember, ..._laborder	Laboratoires, personnel rattaché, prescriptions d'analyses et résultats
pharmacy_medicinequery, ..._medicineanswer	Demandes de disponibilité d'un médicament et réponses des pharmacies
audit_auditevent	Journal d'audit (aucune modification ni suppression possible par l'application)

Identifiants : UUID aléatoires (aucun identifiant séquentiel devinable dans les URL). Montants : entiers en francs CFA. Heures : stockées en UTC, affichées à l'heure de Dakar (UTC+0 toute l'année).

1.5 Intégrations externes

Service	Usage	Mode de sécurisation	Comportement sans configuration
PayDunya	Paielement des consultations et abonnements	Clés serveur ; statut relu auprès de PayDunya (jamais cru depuis le navigateur ou la notification)	Paielement au cabinet uniquement
Twilio	SMS, WhatsApp (rappels, codes, robot)	Jeton serveur ; webhook entrant vérifié par signature ; repli WhatsApp → SMS	Envoi désactivé (journalisé)

Service	Usage	Mode de sécurisation	Comportement sans configuration
Agrégateur USSD	Menu USSD	Secret partagé (en-tête), numéro fourni par l'opérateur	Point d'entrée refusé
Web Push	Notifications sur le téléphone	Clés VAPID ; abonnements expirés supprimés	Fonction masquée
Jitsi	Vidéo	Nom de salle aléatoire, lien visible seulement pour le médecin et son patient	—
Agenda personnel du médecin (iCal)	Import des occupations	HTTPS uniquement, adresses internes refusées (y compris après redirection), 2 Mo et 15 s maximum, horaires seuls conservés	Fonction inactive
IA (compatible OpenAI)	Assistant d'orientation	Clé serveur ; limite de débit ; aucun stockage des symptômes	Message « non configuré »
SMTP	Emails	Identifiants serveur	Emails affichés dans la console (développement)

1.6 Dépendances principales

Backend (`backend/requirements.txt`) : Django 6.1, djangorestframework, django-tasks-db, pycpg 3, gunicorn, whitenoise, sentry-sdk, python-dotenv, pywebpush. Frontend (`package.json`) : React 19, TanStack Router/Start/Query, Tailwind CSS 4, Radix UI, Leaflet, Recharts, pdf-lib, qrcode, zod.

2. Sécurité

2.1 Principes

1. **Le serveur décide** : chaque requête est authentifiée et chaque accès à une donnée est vérifié par l'API Django, quel que soit ce qu'affiche l'interface.
2. **Le navigateur n'est jamais cru sur parole** : prix, durées, statuts, parts d'assurance, rôles, statuts de paiement et types de fichiers sont déterminés ou contrôlés par le serveur.
3. **Moindre accès aux données de santé** : un professionnel ne voit que ce qui lui est nécessaire, pour une durée et un périmètre définis (§ 2.4), et chaque consultation est tracée.
4. **Traçabilité inaltérable** : journal d'audit et journal comptable ne peuvent être ni modifiés ni supprimés par l'application.
5. **Validation systématique des entrées** : types, longueurs, formats, UUID, listes de valeurs autorisées.

2.2 Authentification

Élément	Implémentation
Méthodes	Téléphone + code SMS à 6 chiffres (méthode par défaut) ; email + mot de passe
Mots de passe	10 caractères minimum, validateurs Django (mots courants, similarité), hachage PBKDF2-SHA256
Codes SMS	Stockés sous forme d'empreinte, 10 minutes de validité, 5 essais, 3 envois par 10 minutes et par numéro
Double authentification	TOTP (applications d'authentification), codes de secours à usage unique (empreintes), anti-rejeu du même code. Obligatoire pour tout compte professionnel (médecin, pharmacien, clinique, secrétariat, administrateur) : tant qu'elle n'est pas activée, l'API refuse tout sauf les routes de compte (<code>accounts/security.py</code>). La connexion par mot de passe seul de <code>/django-admin/</code> est supprimée. L'administration peut la réinitialiser (téléphone perdu), action journalisée
Comptes	Changement de mot de passe (déconnexion des autres appareils, email d'alerte) ; suspension d'un compte par l'administration (sessions coupées, fiche médecin retirée de l'annuaire), journalisée avec son motif
Session	Cookie <code>HttpOnly</code> , <code>Secure</code> en production, <code>SameSite=Lax</code> , 14 jours ; protection CSRF (jeton en en-tête). Comptes professionnels : fermée après 30 minutes sans activité de l'utilisateur (<code>PRO_IDLE_MINUTES</code> , <code>IdleTimeoutMiddleware</code>) ; les rafraîchissements automatiques de l'écran ne comptent pas (l'application transmet le temps écoulé depuis le dernier clic ou la dernière frappe) ; retour à la connexion puis à la page en cours
Nouvel appareil	Chaque navigateur reçoit un jeton aléatoire (cookie <code>HttpOnly</code> , conservé haché en base, oublié après 2 ans sans usage). Une connexion depuis un navigateur jamais utilisé par le compte déclenche une alerte au titulaire (email, ou SMS s'il n'a pas d'email) : vol de mot de passe, de session ou de puce téléphonique (« SIM swap ») repéré immédiatement
Réinitialisation	Lien signé à usage unique envoyé par email ; réponse identique que le compte existe ou non
Canaux sans application	WhatsApp : signature Twilio vérifiée ; USSD : secret partagé avec l'agrégateur. Le numéro, garanti par l'opérateur, identifie le patient ; seuls les comptes au numéro vérifié sont utilisés

2.3 Rôles

Rôle	Attribution
Patient	Inscription
Médecin	Fiche créée dans l'espace pro ; publiée seulement après validation par l'administration d'une preuve d'inscription à l'Ordre

Rôle	Attribution
Responsable / secrétariat de clinique	Création d'un établissement / ajout par le responsable
Secrétaire d'un médecin seul	Ajoutée par le médecin (« Mon secrétariat ») ; cabinet créé en coulisses, mêmes droits qu'un secrétariat de clinique
Médecin remplaçant	Proposé par le titulaire, accepté par le remplaçant (médecin vérifié) ; droits limités à la période et aux patients concernés
Pharmacien	Rattachement à une officine par l'administration, après vérification
Laboratoire d'analyses	Rattachement à un laboratoire par l'administration, après vérification ; ne voit que les prescriptions que les patients lui ont envoyées
Administrateur	Attribution manuelle (compte <code>is_staff</code>) ; peut suspendre un compte (sessions coupées)

Tous les rôles autres que « patient » exigent la double authentification (§ 2.2).

2.4 Matrice des droits (données sensibles)

Donnée	Patient	Médecin	Clinique	Pharmacien	Confrère (télé-expertise)
Profil de santé	Lecture / écriture	Si RDV confirmé ou terminé avec lui	—	—	Si joint à une demande, patient informé
Documents déposés	Tous les siens	Seulement ceux que le patient lui a partagés, et s'il le suit	—	—	Seulement ceux joints à la demande
Comptes-rendus, notes privées	Comptes-rendus	Les siens	—	—	—
Ordonnance	Les siennes	Celles qu'il a rédigées	—	Uniquement celle transmise à son officine, tant qu'elle est en cours	—
Carnet de vaccination	Le sien et celui de ses enfants	Inscription d'une dose lors d'un RDV confirmé	—	—	—
RDV	Les siens	Son agenda	Agenda de ses médecins	—	—
Justificatifs du médecin	—	Les siens	—	—	— (administration seulement)

Médecin remplaçant : pendant la période du remplacement (de la veille jusqu'à 30 jours après la fin), il voit les RDV qu'il assure, les comptes-rendus et ordonnances du titulaire pour les patients qu'il reçoit, et les documents que ces patients ont partagés avec le titulaire ; jamais les notes privées du titulaire. Il signe ses documents à son nom et à son numéro d'Ordre, avec la mention « remplaçant du Dr X ». Le titulaire voit ce que son remplaçant a rédigé pour ses patients.

Laboratoire : nom, âge, sexe et téléphone du patient, analyses demandées et médecin prescripteur, pour les seules prescriptions que le patient lui a adressées ; dépose les résultats (type réel contrôlé) mais ne lit pas le reste du dossier ; consultation journalisée. **Pharmacie (disponibilité d'un médicament)** : nom du médicament

seulement, jamais l'identité du patient. **Mesures à domicile** : mêmes règles que le profil de santé (médecin avec RDV confirmé ou terminé).

Secrétariat (clinique ou cabinet) : agenda, prise de RDV, fichier patients (noms, téléphones) ; aucun accès aux dossiers médicaux, comptes-rendus, ordonnances ni documents.

Chaque règle ci-dessus est couverte par au moins un test automatisé qui tente l'accès interdit.

2.5 Protections techniques

Menace	Protection
Double réservation	Verrou transactionnel et contrainte d'exclusion PostgreSQL sur les plages horaires
Manipulation des prix ou des parts d'assurance	Calcul serveur ; valeurs figées sur le RDV à la réservation
Faux paiement	Statut relu auprès de PayDunya ; montant contrôlé ; écritures comptables idempotentes
Double virement, double remboursement	Verrous en base ; une seule demande de virement en cours ; une seule écriture par paiement
Fichier piégé (HTML/SVG déguisé)	Type réel déterminé par le contenu (PDF, JPEG, PNG, WebP uniquement), 6 Mo maximum, stockage hors du dossier public, service avec <code>Content-Security-Policy: sandbox et nosniff</code>
Virus dans un fichier déposé	Analyse antivirus ClamAV (service <code>clamav</code> , signatures mises à jour automatiquement) de chaque fichier avant stockage : documents, résultats d'analyses, pièces jointes, justificatifs, photos, signatures. Fichier infecté refusé ; antivirus injoignable = dépôt refusé (jamais de fichier non inspecté) et alerte de supervision
Vol du disque, d'un volume ou d'une sauvegarde	Chiffrement de chaque fichier sur le disque (Fernet : AES-128-CBC + HMAC-SHA256, <code>sunusante/uploads.py</code>) avec une clé (<code>FILE_ENCRYPTION_KEYS</code>) conservée hors du serveur de fichiers et hors des sauvegardes ; fichier altéré refusé ; rotation de clé sans coupure (<code>encrypt_files --rotate</code>)
Poste de cabinet ou de clinique laissé ouvert	Déconnexion automatique des comptes professionnels après 30 minutes sans activité
Faible connue dans une bibliothèque	Contrôle automatique à chaque modification : <code>npm audit</code> (interface) et <code>pip-audit</code> (serveur) dans l'intégration continue
Script injecté (XSS)	React échappe les contenus ; CSP stricte sans <code>unsafe-inline</code> pour les scripts (empreintes calculées au build) ; cookie de session inaccessible au JavaScript
Clic détourné (clickjacking)	<code>frame-ancestors 'none'</code> et <code>X-Frame-Options: DENY</code> , sauf le module de réservation intégrable, qui ne contient ni connexion ni paiement
Abus et force brute	Limites de débit : connexion 10/min, codes SMS 10/h, réservations 20/h, assistant IA 15/min, recherches publiques 30/min
Messages répétés par Twilio ou l'opérateur USSD	Réponse mémorisée par identifiant de message / saisie : aucune double réservation
Sondage d'annuaire	La recherche de doublons en clinique ne révèle jamais l'existence d'un compte pour une personne inconnue de la clinique
Faux documents médicaux	Référence aléatoire vérifiable publiquement ; la vérification n'affiche ni contenu médical ni identité complète
Interception	HTTPS obligatoire (HSTS un an) ; redirection HTTP → HTTPS
Requête forgée vers le réseau interne (SSRF) via l'import d'agenda	HTTPS seulement ; résolution DNS vérifiée (adresses privées, locales, réservées refusées), à chaque redirection ; taille et durée limitées

Menace	Protection
Fuite de l'agenda exporté	Lien à jeton aléatoire (256 bits), révocable ; initiales et motif seulement, sans téléphone ni motif libre
Données hors ligne sur un téléphone partagé	Données personnelles effacées du cache à la déconnexion ; aucune écriture hors ligne
Vol du mot de passe d'un professionnel	Double authentification obligatoire ; la console technique <code>/django-admin/</code> n'a plus de connexion par mot de passe seul
Compte compromis ou professionnel radié	Suspension immédiate par l'administration : sessions supprimées sur tous les appareils, fiche retirée de l'annuaire, republication soumise à une nouvelle validation
Usurpation d'identité d'un médecin vérifié	Nom et spécialité non modifiables en ligne après vérification
Pièce jointe piégée dans la messagerie	Même contrôle que les documents médicaux (type réel, 6 Mo, service en bac à sable) ; lecture réservée au patient et au médecin du fil, lecture par le médecin journalisée
Fuite par export tableur	Exports limités aux données du médecin ou de l'établissement, période d'un an au plus, journalisés (qui, quoi, quelle période)
Photo de profil piégée	Type réel contrôlé (JPEG, PNG, WebP), 2 Mo maximum, servie avec la même politique « bac à sable » que les documents

2.6 Journal d'audit

Inscrits dans une table inaltérable : connexions et échecs, activation/désactivation de la 2FA, changements de mot de passe, consultation d'une fiche patient, d'un document, d'une ordonnance (y compris par une pharmacie, un confrère ou un remplaçant), rédaction de comptes-rendus et certificats, modification d'une fiche médecin ou d'une officine, exports et suppressions de compte, actions d'administration (validations, virements, remboursements, modération, consultation des justificatifs, recherches de comptes, suspensions, réinitialisations de 2FA, avec leur motif). Le patient voit dans son dossier qui a consulté ses données ; l'administration voit l'ensemble. Conservation du journal : 5 ans par défaut (réglable, à valider 🛠️).

2.7 Secrets et configuration

Aucun secret dans le code source. Les clés (Django, base, PayDunya, Twilio, USSD, VAPID, IA, SMTP, Sentry) sont lues dans des variables d'environnement (`deploy/.env` , non versionné). En production, Django refuse de démarrer sans clé secrète ni clé de chiffrement des fichiers (`FILE_ENCRYPTION_KEYS` , à garder aussi dans un coffre hors du serveur : sans elle, documents et sauvegardes sont illisibles), active les cookies sécurisés, HSTS et la redirection HTTPS ; `manage.py check --deploy` est exécuté par l'intégration continue.

2.8 Tests de sécurité réalisés

- **230 tests automatisés de l'API**, dont les tentatives d'accès interdites de la matrice § 2.4 (y compris pour un remplaçant, une secrétaire, un médecin sans lien avec le patient), les manipulations de prix et de parts, les fichiers piégés, les doubles réservations, les webhooks non signés, les secrets USSD invalides, la réutilisation de session USSD par un autre numéro, les doubles notifications de paiement, le blocage des professionnels sans double authentification, la suspension de compte (sessions coupées), le chiffrement des fichiers sur le disque (et le refus d'un fichier altéré), le refus d'un fichier infecté ou non analysable, la déconnexion après inactivité (sans prolongation par les rafraîchissements automatiques) et l'alerte de connexion depuis un nouvel appareil.
- **Parcours de bout en bout** dans un navigateur réel pour chaque rôle, sur ordinateur et mobile, dont le mode hors ligne et l'effacement des données à la déconnexion sur le build de production, et l'activation

imposée de la double authentification.

- **Failles corrigées pendant les audits :**

- le type de fichier annoncé par le navigateur était accepté tel quel pour les documents médicaux (page HTML exécutable au nom du site) : type désormais déterminé par le contenu, fichiers servis dans un bac à sable ;
- la console technique `/django-admin/` permettait une connexion par mot de passe seul, contournant la double authentification : elle passe désormais par la connexion Fajma ;
- l'ajout en double d'un membre de secrétariat provoquait une erreur serveur : contrôle préalable.

À faire : test d'intrusion externe, revue de la configuration de l'hébergement réel.

3. Données personnelles et conformité

Cette section décrit les faits techniques utiles à l'analyse juridique. **Elle ne constitue pas un avis juridique.** Les points marqués ⚖️ doivent être validés par un juriste spécialisé en droit du numérique et de la santé au Sénégal.

3.1 Cadre applicable (à confirmer ⚖️)

- **Loi n° 2008-12 du 25 janvier 2008** sur la protection des données à caractère personnel et son décret d'application ; autorité de contrôle : **CDP**. Vérifier l'état de la réforme de cette loi au moment de la cession.
- Les données de santé sont des **données sensibles** : leur traitement relève en principe d'une **autorisation préalable de la CDP**.
- **Transferts hors du Sénégal** : encadrés (pays adéquat ou autorisation). Voir § 3.3.
- Exercice de la médecine, téléconsultation, ordonnance et certificat électroniques, télé-expertise : règles de l'Ordre national des médecins et du ministère de la Santé.
- Pharmacies : transmission d'ordonnances à une officine choisie par le patient (règles de l'Ordre des pharmaciens).
- Encaissement pour le compte des médecins et prélèvement d'une commission : qualification juridique à établir (mandat d'encaissement, statut au regard de la réglementation des paiements de l'UEMOA).
- Assurances : tiers payant et échange d'informations avec les organismes (IPM, mutuelles, assureurs) à encadrer par convention.

3.2 Inventaire des données

Catégorie	Données	Personnes	Finalité
Identité et contact	Nom, email, téléphone (vérifié), ville, langue	Tous les utilisateurs	Compte, rappels
Proches	Nom, lien, date de naissance, téléphone	Enfants et proches	Prise de RDV, carnet de vaccination
Rendez-vous	Médecin, date, motif libre, réponses au questionnaire, canal	Patients	Organisation des soins
Santé	Profil (groupe sanguin, allergies, antécédents, traitements), comptes-rendus, ordonnances, certificats, arrêts de travail, documents déposés, messages, vaccins, suivi de grossesse	Patients, enfants	Suivi médical
Santé	Symptômes décrits à l'assistant IA	Visiteurs	Orientation — non conservés
Santé	Mesures à domicile (tension, glycémie, poids), rappels de médicaments, prescriptions et résultats d'analyses	Patients, proches	Suivi médical
Demandes aux pharmacies	Nom du médicament, précision, réponses (sans identité transmise à la pharmacie)	Patients	Éviter les déplacements inutiles
Assurance	Organisme, numéro d'adhérent, taux de prise en charge	Patients	Tiers payant, feuille de soins
Paieement	Montant, moyen, références de transaction et de virement	Patients, médecins	Encaissement, reversement

Catégorie	Données	Personnes	Finalité
Professionnels	Fiche, tarifs, disponibilités, justificatifs (diplôme, inscription à l'Ordre, pièce d'identité)	Médecins	Annuaire, vérification
Patients sans compte	Nom, téléphone saisis par le secrétariat	Patients au guichet	RDV, rappels
Techniques	Journal d'audit (adresse IP, navigateur), journaux serveur	Tous	Sécurité, preuve des accès

3.3 Sous-traitants et flux hors du Sénégal

Prestataire	Rôle	Données transmises	Localisation
Hébergeur (au choix)	Serveur, base, fichiers	Toutes	Au choix — hébergement au Sénégal possible
Twilio / Meta (WhatsApp)	SMS, WhatsApp, robot WhatsApp	Numéro, nom, médecin, date ; messages du robot	États-Unis
Agrégateur USSD	Menu USSD	Numéro, saisies du menu	Selon contrat (opérateurs sénégalais)
PayDunya	Palement	Montant, référence	Sénégal
Service push des navigateurs (Google, Apple, Mozilla)	Notifications	Titre et court texte de la notification (chiffrés de bout en bout)	Hors Sénégal
Jitsi meet.jit.si (tant qu'il n'est pas auto-hébergé)	Vidéo	Flux audio/vidéo de la consultation	Hors Sénégal, sans contrat
Fournisseur IA (Google Gemini par défaut)	Assistant d'orientation	Symptômes saisis	Hors Sénégal
OpenStreetMap	Fonds de carte	Adresse IP du visiteur	Hors Sénégal
Google Fonts	Polices	Adresse IP du visiteur	Hors Sénégal
Sentry (facultatif)	Suivi des erreurs	Traces techniques (sans données personnelles : option désactivée)	Selon compte

⚖️ Pour les données de santé, la voie la plus simple est l'hébergement au Sénégal (base et fichiers) et une instance Jitsi locale ; les autres transferts portent sur des données limitées (SMS, notifications) et doivent être couverts par les contrats et autorisations.

3.4 Droits des personnes

Droit	Mise en œuvre
Information	Projets de CGU et de politique de confidentialité intégrés au site (à valider ⚖️) ; mention à chaque partage de dossier (pharmacie, confrère)
Accès	Dossier complet consultable ; journal des accès montrant quel professionnel a consulté quoi
Rectification	Profil, profil de santé, proches, assurances, carnet modifiables
Portabilité	Export complet des données en JSON depuis le dossier
Effacement	Suppression du compte en libre-service (anonymisation des données qui doivent être conservées)
Maîtrise du partage	Partage des documents document par document et médecin par médecin ; envoi d'ordonnance à une pharmacie choisie ; information préalable du patient pour la télé-expertise

Droit	Mise en œuvre
Langue	Interface, SMS et menus en français, wolof ou anglais

3.5 Conservation

Purge automatique chaque nuit (`purge_data` , durées réglables par variables d'environnement) :

Donnée	Durée par défaut	Traitement
Sessions expirées	À expiration	Suppression
Codes SMS de connexion	1 jour	Suppression
Conversations WhatsApp / USSD	30 jours	Suppression
SMS envoyés (numéro et texte)	1 an	Suppression
Notifications de l'application	1 an	Suppression
Occupations importées des agendas personnels	7 jours après la date	Suppression
Identité des patients sans compte (saisi au guichet)	5 ans après le RDV	Anonymisation (le RDV reste pour les statistiques)
Journal d'audit	5 ans 🏛️	Suppression
Données médicales (dossiers, comptes-rendus, ordonnances, certificats, documents, carnets)	Aucune purge automatique	Durée légale à fixer 🏛️
Données de paiement et journal comptable	Aucune purge automatique	Obligations comptables à fixer 🏛️

Un compte supprimé par son titulaire est anonymisé immédiatement (documents déposés effacés, identité remplacée).

3.6 Points d'attention dans l'application

- **Allégations commerciales** : les chiffres de la page d'accueil (médecins, villes, praticiens par spécialité, note moyenne) sont calculés à partir de la base ; la note moyenne n'est affichée qu'à partir de 20 avis.
- **Calendriers médicaux** : le calendrier vaccinal (PEV) et le rythme des consultations prénatales (8 contacts OMS) sont des références à faire valider ; l'application précise qu'elle complète le carnet papier.
- **Certificats et arrêts de travail** : un arrêt ne peut pas débuter plus de 2 jours avant la consultation ; la vérification publique ne révèle que les initiales du patient.
- **Chiffrement** : transport (HTTPS) garanti ; **fichiers (documents médicaux, résultats, pièces jointes, justificatifs, signatures) chiffrés par l'application** avant écriture sur le disque, donc aussi dans les sauvegardes ; sauvegardes elles-mêmes chiffrées (AES-256). La base de données reste à chiffrer au niveau de l'hébergement (disque chiffré) — **à vérifier** sur l'infrastructure retenue.

4. Exploitation et déploiement

4.1 Environnements

Environnement	Composition
Développement	Django (<code>runserver</code>) + Vite ; SQLite ; envois exécutés immédiatement ; codes SMS affichés à l'écran
Production	Docker Compose : PostgreSQL 17, API (gunicorn), worker (file de tâches), planificateur, nginx
Recette (recommandée)	Même composition que la production, données de démonstration (<code>seed_demo --accounts --activity</code>)

4.2 Installation locale

Voir le `README.md` à la racine : environnement Python, `migrate`, `seed_demo`, `runserver`, puis `npm run dev`.

4.3 Mise en production

```
cp deploy/.env.example deploy/.env      # base, clé secrète, domaine, PayDunya, Twilio, USSD, push, Jit
docker compose -f deploy/docker-compose.yml --env-file deploy/.env up -d --build
docker compose -f deploy/docker-compose.yml exec backend python manage.py createsuperuser
docker compose -f deploy/docker-compose.yml run --rm backend python manage.py vapid_keys    # une fois
```

- Les migrations s'appliquent au démarrage de l'API ; la liste des organismes d'assurance est créée par migration.
- HTTPS : répartiteur TLS en amont (transmettant `X-Forwarded-Proto`) ou certificats dans nginx.
- Webhooks à déclarer : PayDunya (`/api/payments/paydunya/webhook`), Twilio statut SMS (`/api/notifications/twilio-status?token=...`), Twilio WhatsApp entrant (`/api/bots/whatsapp`), agrégateur USSD (`/api/bots/ussd`, en-tête `X-Ussd-Secret`).
- Application Android : génération Trusted Web Activity (`tw-manifest.json`, Bubblewrap) et empreinte de la clé de signature dans `public/.well-known/assetlinks.json`.
- **Premier administrateur** : `createsuperuser`, puis connexion sur le site ; l'activation de la double authentification est imposée dès la première connexion.
- **À vérifier** : exécution effective de la composition Docker sur le serveur cible (validée par `docker compose config` seulement dans l'environnement d'audit) et premier test de restauration (`docker compose exec backup sh /restore-test.sh`).

4.4 Tâches en arrière-plan

Tâche	Fréquence	Rôle
<code>worker</code> (<code>manage.py db_worker</code>)	Continu	SMS, WhatsApp, emails, notifications push, sans ralentir les requêtes
<code>scheduler</code> (<code>manage.py send_reminders</code>)	10 minutes	Rappels de RDV (24 h, 2 h), rappels des médecins, vaccins des enfants, consultations prénatales, prises de médicaments
<code>scheduler</code> (<code>manage.py sync_calendars</code>)	10 minutes	Relecture des agendas personnels des médecins
<code>scheduler</code> (<code>manage.py monitor</code>)	10 minutes	Supervision et alertes email (§ 4.6)

Tâche	Fréquence	Rôle
<code>scheduler</code> (<code>manage.py purge_data</code>)	Chaque nuit vers 3 h	Purge des données techniques (§ 4.6 bis)
<code>backup</code> (<code>backup.sh</code> , <code>restore-test.sh</code>)	Chaque jour / le 1er du mois	Sauvegarde chiffrée / test de restauration
<code>clamav</code> (<code>clamd</code> + <code>freshclam</code>)	Continu	Analyse antivirus des fichiers déposés ; signatures mises à jour plusieurs fois par jour. Prévoir ≈ 2 Go de mémoire

4.5 Sauvegardes et reprise

- Automatique : le service `backup` (`deploy/backup.sh`) produit chaque jour une archive de la base (`pg_dump`) et du volume `private_media` (documents médicaux, justificatifs, signatures et cachets des médecins) dans `deploy/backups`, chiffrée en AES-256 si `BACKUP_PASSPHRASE` est défini, conservée 30 jours.
- À faire par l'exploitant : copier chaque nuit `deploy/backups` hors du serveur (`rclone`, `scp`...), garder la phrase secrète **et la clé** `FILE_ENCRYPTION_KEYS` dans un coffre séparé : les fichiers de la sauvegarde sont chiffrés par l'application et ne peuvent être relus qu'avec cette clé.
- Mise en service sur des données existantes : `python manage.py encrypt_files` chiffre les fichiers encore en clair (sans risque à relancer) ; après un changement de clé, `encrypt_files --rotate`.
- Test de restauration automatique le 1er de chaque mois (`deploy/restore-test.sh`) : la dernière sauvegarde est restaurée dans une base temporaire, vérifiée (comptes, rendez-vous, fichiers) puis effacée. Lancement manuel : `docker compose exec backup sh /restore-test.sh`.
- Objectifs recommandés : perte de données maximale 24 h (1 h avec archivage continu PostgreSQL), reprise en 4 h.

4.6 Supervision

- `/api/health` : vérifie l'API et la base (utilisé par le contrôle de santé du conteneur).
- Erreurs serveur et navigateur : Sentry (facultatif, `SENTRY_DSN`), sans données personnelles.
- Administration : SMS en échec avec relance, file des remboursements et virements, justificatifs à vérifier, avis à modérer, tableau de pilotage.
- `python manage.py monitor` (planificateur, toutes les 10 min) : base, rappels SMS en retard, taux d'échec SMS, âge et taille de la dernière sauvegarde, espace disque. Email aux adresses `ALERT_EMAILS` (une fois par problème toutes les 6 h, puis « résolu »).
- **À faire par l'exploitant** : un service de surveillance externe (UptimeRobot, Better Stack — gratuits) qui appelle <https://www.fajma.sn/api/health> chaque minute et prévient par SMS/email : si le serveur entier tombe, la supervision interne ne peut plus rien envoyer.

4.6 bis Conservation des données

`python manage.py purge_data` (chaque nuit vers 3 h, `--dry-run` pour simuler) supprime les données techniques au-delà des durées de `RETENTION_DAYS` (réglables par variables d'environnement) : sessions expirées, codes SMS (1 j), conversations WhatsApp/USSD (30 j), SMS envoyés et notifications (1 an), créneaux d'agendas importés (7 j), journal des accès (5 ans), identité des patients sans compte sur les RDV passés (anonymisée après 5 ans).

Aucune donnée médicale n'est purgée automatiquement : durées légales à fixer avec un juriste et la CDP



4.7 Performance et montée en charge

- `gunicorn` (3 processus par défaut, à ajuster) ; fichiers du site servis et mis en cache par `nginx`.

- Annuaire : calcul des prochains créneaux par médecin à chaque recherche — à mettre en cache au-delà de quelques centaines de médecins.
- Réseau mobile lent : application mise en cache sur le téléphone, lectures récentes disponibles hors ligne.

4.8 Qualité du code

Contrôle	Outil	État
Tests de l'API	<code>python manage.py test</code> (SQLite et PostgreSQL en CI)	148 tests, tous au vert
Parcours de bout en bout	Navigateur piloté (Edge), 17 parcours, 104 étapes	Tous au vert
Typage	<code>tsc --noEmit</code>	Sans erreur
Lint / format	ESLint + Prettier	0 erreur
Sécurité Django	<code>manage.py check --deploy</code>	Sans erreur
Dépendances	<code>npm audit</code> en CI	À surveiller à chaque version

5. Risques ouverts et plan d'action

Gravité : ● bloquant pour la commercialisation · ● à traiter avant la montée en charge · ● amélioration. ⚖️ : volet juridique ou réglementaire.

5.1 Registre des risques

Réf.	Gravité	Risque	Action recommandée
R-01	● ⚖️	Pas encore d'autorisation CDP pour le traitement de données de santé	Constituer et déposer le dossier (ce dossier technique en fournit la matière)
R-02	● ⚖️	Transferts hors du Sénégal (§ 3.3) non encore encadrés	Hébergement au Sénégal ; contrats et autorisations pour les flux restants
R-03	●	Téléconsultation sur le serveur public <code>meet.jit.si</code>	Instance Jitsi auto-hébergée (paramètre <code>JITSI_DOMAIN</code>) ou service contractualisé
R-04	● ⚖️	CGU, politique de confidentialité et contrats (médecins, cliniques, pharmacies, organismes d'assurance) à l'état de projet	Rédaction et validation juridique ; conventions de tiers payant
R-05	● ⚖️	Encaissement pour le compte des médecins et commission : qualification juridique	Avis juridique ; convention avec PayDunya
R-06	●	Aucun test d'intrusion externe	Test d'intrusion sur l'environnement de recette avant ouverture
R-07	●	Virements aux médecins et remboursements exécutés manuellement par l'administration (le suivi est automatisé, pas le transfert)	API de décaissement (PayDunya Disburse, Wave Business) après validation juridique
R-08	●	Calendrier vaccinal PEV et rythme des consultations prénatales non validés par une autorité sanitaire	Validation par la Direction de la Prévention ; mise à jour de <code>backend/carnet/schedules.py</code>
R-09	●	Textes wolof non relus par un locuteur natif	Relecture par un traducteur médical (<code>src/lib/i18n/wo.ts</code> , <code>backend/bots/texts.py</code> , SMS)
R-11	●	WhatsApp : Meta exige des modèles approuvés pour un premier message	Faire approuver les modèles ; repli SMS automatique en attendant
R-12	● ⚖️	Durées de conservation des données médicales non fixées	Fait : purge nocturne des données techniques (<code>purge_data</code>). Reste : fixer avec un juriste les durées médicales et celles du journal (5 ans par défaut)
R-13	✓	Double authentification facultative pour les professionnels	Traité le 30/09/2026 : obligatoire pour médecins, cliniques, secrétariats, pharmaciens et administrateurs (<code>MFA_REQUIRED_FOR_PROS</code>) ; la console <code>/django-admin/</code> passe par la même connexion
R-14	●	Surveillance externe à abonner	Fait : supervision interne avec alertes email (<code>monitor</code>), test de restauration mensuel automatique. Reste : créer le moniteur externe sur <code>/api/health</code> et renseigner <code>ALERT_EMAILS</code>
R-15	●	Temps réel par interrogation de la base toutes les 2 s (suffisant jusqu'à quelques milliers de connectés)	Passer à PostgreSQL LISTEN/NOTIFY ou Redis au-delà

Réf.	Gravité	Risque	Action recommandée
R-16	●	Calcul des prochains créneaux à chaque recherche	Mise en cache au-delà de quelques centaines de médecins
R-17	●	Autres langues nationales (pulaar, sérère, diola...)	Ajouter un fichier de traduction par langue, avec des traducteurs natifs
R-18	●	Données de l'ancien prototype (Supabase / Lovable Cloud)	Décider de leur reprise (script d'import) ou de leur suppression, puis fermer les anciens comptes

5.2 Plan d'action proposé

Avant tout lancement commercial : R-01 à R-06 ; hébergement de production au Sénégal, HTTPS, sauvegardes chiffrées testées ; contrats Twilio, agrégateur USSD et PayDunya en production.

Dans les 3 mois suivant le lancement : R-07, R-08, R-09, R-11, R-12, R-14.

Amélioration continue : R-15 à R-18.

5.3 Risques traités depuis la version 1 du dossier

Contrôle d'accès appliqué par le serveur et testé ; journal d'audit visible par le patient ; accès des médecins aux documents limité au partage explicite ; double authentification ; connexion par code SMS ; limites de débit ; en-têtes de sécurité et CSP stricte ; cookies HttpOnly ; mots de passe de 10 caractères ; export et suppression du compte ; reversement aux médecins, commission et remboursements ; tests automatisés et intégration continue ; déploiement reproductible ; contrôle du type réel des fichiers déposés ; chiffres de la page d'accueil issus de la base (plus d'allégations écrites en dur) ; code et données indépendants de Lovable et de Supabase.

Depuis la version 2.0 : double authentification obligatoire pour tous les professionnels et administrateurs (R-13) ; suppression de la connexion par mot de passe seul de la console technique ; suspension de comptes ; purge nocturne des données techniques (R-12, partie technique) ; supervision avec alertes et test de restauration mensuel automatique (R-14, partie technique).

Version 2.4 : chiffrement des fichiers sur le disque par l'application ; antivirus sur tous les fichiers déposés ; déconnexion des professionnels après 30 minutes d'inactivité ; alerte de connexion depuis un nouvel appareil (y compris contre le vol de puce) ; contrôle automatique des failles connues des bibliothèques serveur.

6. Informations pour une cession (due diligence)

Ce chapitre rassemble ce qu'un acquéreur ou un investisseur vérifie en priorité. Les points ⚖️ relèvent d'un juriste ; les montants sont des ordres de grandeur à confirmer par devis.

6.1 Propriété et actifs cédés

Actif	Contenu	Point à vérifier
Code source	Backend Django, frontend React, scripts de déploiement, tests, ce dossier	⚖️ Chaîne de droits : contrats ou cessions de droits d'auteur de chaque contributeur (y compris code produit avec des outils d'assistance)
Marque et nom de domaine	« Fajma », <code>fajma.sn</code> (référéncé dans la configuration)	⚖️ Dépôt de marque (OAPI) et titulaire du domaine
Données	Comptes, rendez-vous, dossiers médicaux, paiements	⚖️ Une cession de base de données de santé suppose l'accord de la CDP et l'information des personnes
Comptes prestataires	Hébergeur, PayDunya, Twilio, agrégateur USSD, fournisseur IA, SMTP, Google Play	Transfert des comptes ou re-création au nom de l'acquéreur ; les clés sont hors du code (§ 2.7)
Application Android	Configuration Trusted Web Activity (<code>tw-manifest.json</code>)	Clé de signature Play Store : à conserver et transférer (sa perte empêche toute mise à jour)

Le code ne contient **aucun secret** et **aucune dépendance** à Lovable ou Supabase (plateformes du prototype).

6.2 Licences des composants libres

Inventaire établi le 30/09/2026 à partir des paquets installés.

Licence	Composants	Conséquence pour une exploitation commerciale
MIT, BSD, ISC, Apache 2.0, PSF	Django, Django REST Framework, React, TanStack, Tailwind, Radix UI, Leaflet, Recharts, pdf-lib, gunicorn, cryptography, requests... (la quasi-totalité : 56 paquets frontend sur 56, 37 paquets Python sur 44)	Usage commercial libre ; conserver les mentions de licence
LGPL 3.0	<code>psycopg</code> (connexion PostgreSQL), <code>recurring-ical-events</code> , <code>x-wr-timezone</code> (lecture des agendas)	Utilisables dans un produit propriétaire sans publier le code de Fajma, tant que ces bibliothèques ne sont pas modifiées ; en cas de modification, publier les modifications de la bibliothèque
MPL 2.0	<code>certifi</code> , <code>pywebpush</code> , <code>py-vapid</code>	Usage libre ; les fichiers de ces bibliothèques modifiés restent sous MPL

Aucune licence « contaminante » (GPL, AGPL) n'impose de publier le code de Fajma. Le code propre de Fajma n'est pas publié sous licence libre. ⚖️ Faire confirmer l'inventaire par un outil d'audit de licences au moment de la cession.

6.3 Dépendance aux prestataires

Prestataire	Remplaçable ?	Effort de remplacement
Hébergeur	Oui : Docker Compose standard, aucun service propriétaire	Faible (déploiement + restauration d'une sauvegarde)

Prestataire	Remplaçable ?	Effort de remplacement
PayDunya	Oui : un seul module (backend/payments/paydunya.py)	Moyen (nouveau module + contrat)
Twilio (SMS, WhatsApp)	Oui : un seul module d'envoi (backend/notifications/sms.py)	Moyen (opérateur SMS local, fournisseur WhatsApp Business)
Agrégateur USSD	Oui : protocole simple, point d'entrée unique	Faible à moyen
Jitsi	Oui : logiciel libre, auto-hébergeable (JITSI_DOMAIN)	Faible
Fournisseur IA	Oui : toute API compatible OpenAI (variable d'environnement)	Nul

6.4 Coûts d'exploitation (ordres de grandeur, à confirmer)

Poste	Démarrage	Remarque
Serveur (4 vCPU, 8 Go, 100 Go SSD)	Quelques dizaines d'euros par mois hors Sénégal ; à chiffrer auprès d'un hébergeur sénégalais	Un seul serveur suffit pour le lancement (§ 4.7)
Stockage des sauvegardes hors site	Quelques euros par mois	Obligatoire (copie hors du serveur)
SMS et WhatsApp	À l'unité (tarif Twilio vers le Sénégal)	Principal coût variable : rappels 24 h et 2 h ; les notifications push sont gratuites
Paieement	Commission par transaction (contrat PayDunya)	Répercutée dans la commission de la plateforme
Jitsi auto-hébergé	Un second serveur selon le volume de téléconsultations	
Assistant IA	Au volume de requêtes	Désactivable
Test d'intrusion	Prestation ponctuelle, puis annuelle recommandée	
Nom de domaine, Play Store	Faible (annuel / unique)	

6.5 Reprise par une autre équipe

- **Compétences** : Python/Django et React/TypeScript, technologies très répandues ; aucun cadre propriétaire.
- **Documentation** : README.md (installation), ce dossier (architecture, sécurité, exploitation), commentaires en français dans le code, décrivant les règles métier.
- **Filets de sécurité** : 230 tests automatisés de l'API, typage TypeScript strict, analyse de code (ESLint, Prettier), intégration continue sur chaque modification.
- **Données de démonstration** : python manage.py seed_demo --accounts --activity crée des comptes de test pour chaque rôle et 12 semaines d'activité simulée.
- **Délai de prise en main estimé** : quelques jours pour un développeur Django/React expérimenté.

6.6 Points ouverts à connaître avant une offre

Voir le [registre des risques](#). En résumé : autorisation CDP et cadre juridique (CGU, encaissement pour le compte des médecins, transferts de données) non encore obtenus ; téléconsultation sur le serveur Jitsi public ; pas encore de test d'intrusion externe ; intégrations PayDunya, Twilio et USSD testées en simulation, sans compte de production ; virements aux médecins exécutés manuellement.